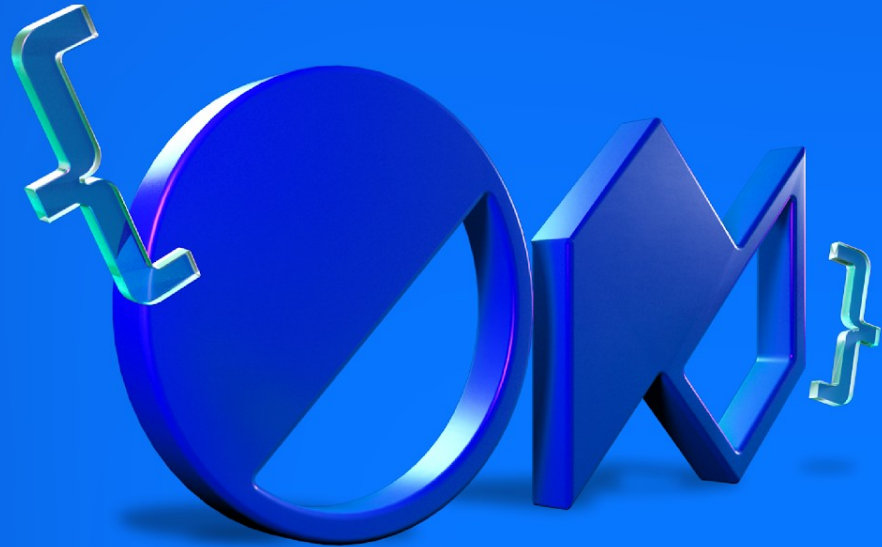


Detection Rules Need a Staging Environment



What we'll cover

01 **The problem**

02 **Multi-tenant blast radius**

03 **The three-space release path**

04 **The promotion tooling**

05 **Further Improvements**

Deconstructing A Detection Rule

M365 Identity OAuth Illicit Consent Grant by Rare Client and User

Created by: krajesh@Jolera.ca on Aug 21, 2026 @ 01:01:06.601 Updated by: elastic on Aug 21, 2026 @ 03:04:38.120

Last response: ● succeeded at Sep 24, 2026 @ 14:54:40.487 Notify when alerts generated

Enable

Add to chat

Edit rule settings

- Overview
- Alerts
- Rule exceptions
- Execution results

About

Details

Investigation guide

Description

Identifies an Microsoft 365 illicit consent grant request on-behalf-of a registered Entra ID application. Adversaries may create and register an application in Microsoft Entra ID for the purpose of requesting user consent to access resources in Microsoft 365. This is accomplished by tricking a user into granting consent to the application, typically via a pre-made phishing URL. This establishes an OAuth grant that allows the malicious client application to access resources in Microsoft 365 on-behalf-of the user.

Author

Elastic

Severity

● Medium

Risk score

47

Reference URLs

- <https://www.wiz.io/blog/midnight-blizzard-microsoft-breach-analysis-and-best-practices>
- <https://docs.microsoft.com/en-us/microsoft-365/security/office-365-security/detect-and-remediate-illicit-consent-grants?view=o365-worldwide>
- <https://www.cloud-architekt.net/detection-and-mitigation-consent-grant-attacks-azuread/>
- <https://docs.microsoft.com/en-us/defender-cloud-apps/investigate-risky-oauth#how-to-detect-risky-oauth-apps>
- <https://learn.microsoft.com/en-us/office/office-365-management-api/office-365-management-activity-api-schema>

Custom highlighted fields

- @timestamp event.action event.outcome o365.audit.UserId o365.audit.ObjectId
- o365.audit.Actor.Type o365.audit.Target.Type
- o365.audit.ModifiedProperties.ConsentAction_Reason.NewValue
- o365.audit.ExtendedProperties.additionalDetails cloud.region

Definition

Index patterns

logs-o365.audit-*

Custom query

```
data_stream.dataset: "o365.audit"
and o365.audit.Actor.Type: 5
and event.action: "Consent to application."
and event.outcome: "success"
and o365.audit.Target.Type: (0 or 2 or 3 or 9 or 10)
and o365.audit.UserId: *
and o365.audit.ObjectId: *
```

Custom query language

KQL

Rule type

New Terms

Related integrations

Microsoft Office 365 Enabled

Required fields

- data_stream.dataset,
- event.action,
- event.outcome,
- o365.audit.Actor.Type,
- o365.audit.ObjectId,
- o365.audit.Target.Type,
- o365.audit.UserId

Timeline template

None

Fields

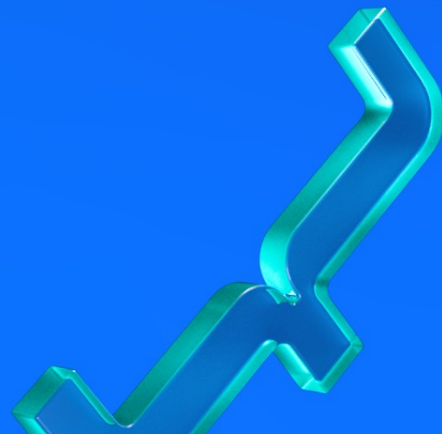
o365.audit.UserId o365.audit.ObjectId

History Window Size

10d



One cluster. Many tenants. Shared rules.



Pain points

Multi-Tenant environment

Rules arrive on a cadence

Analysts absorb the blast

Detection rules (SIEM)

 Some Elastic rules have updates available. Update them to ensure you get the best detection experience. Review and update in [Rule Updates](#).

 8 of your installed Elastic rules have been deprecated and are no longer being maintained

These rules have been deprecated and won't receive new updates or fixes. Duplicate them as custom rules, delete them now, or dismiss this to be reminded in 7 days. [Read the docs to learn more.](#) 

Review deprecated rules

Delete deprecated rules

Installed Rules

1886

Rule Monitoring

1886

Rule Updates

344

What a bad day looks like

Severity levels

Levels	Count ↓
● Medium	5k+
● Low	2k+
● High	1k+



Alerts by name

Rule name	Count ↓
Azure Entra ID Rare App ID for Principal Authentication	3k+
Microsoft Graph First Occurrence of Client Request	2k+
Suspicious Email Access by First-Party Application via Microsoft ...	1k+
Microsoft Entra ID Concurrent Sign-Ins with Suspicious Properties	1k+

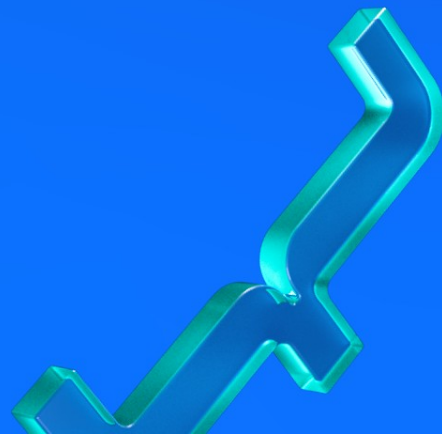
What we learnt the hard way

- **No safe place to test**
- **Alert impact is invisible up front**
- **Volume is not tuneable in advance**
- **Multi-tenant widens every mistake**



Kibana spaces to the rescue

No new licence, no second deployment.



Three spaces, one promotion path

DEV

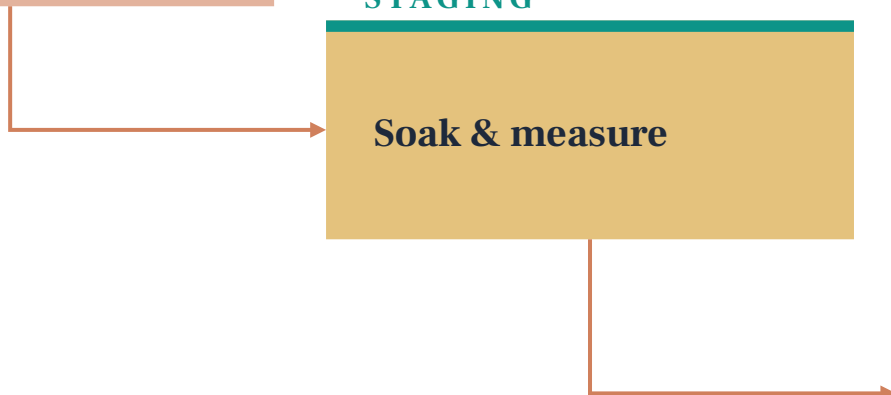
Install & experiment

STAGING

Soak & measure

PROD

Serve tenants



Dev: install everything, notify nobody

Rules run against real production data so we see real behaviour but every notification action is stripped, so no alert reaches a customer.



All rules installed



Actions & connectors removed at install time



**Metadata captured: version, tags, fields,
index patterns**



First-pass triage: is this rule even relevant?

DEV



STAGING



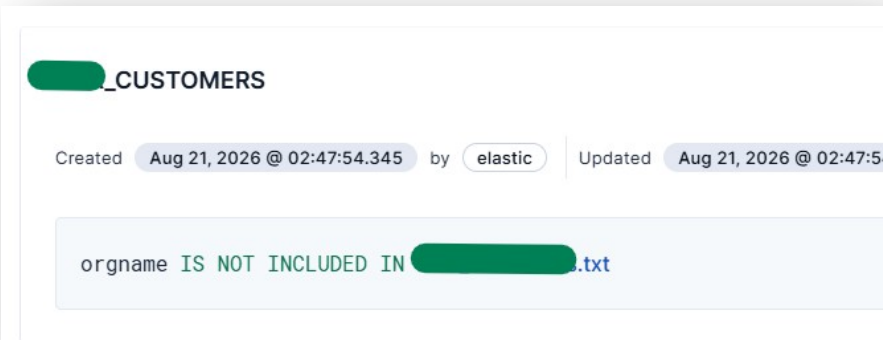
PROD

Gate 1: does this rule query data we actually have?

Missing fields

Rule Exception

Alert Volume Analysis



DEV

>

STAGING

>

PROD

Rule exceptions are added to the detection rule.

Showing 1-1 of 1

🔍 Filter exceptions using simple query syntax, for example, name:"my list"

MSHAPVWPR

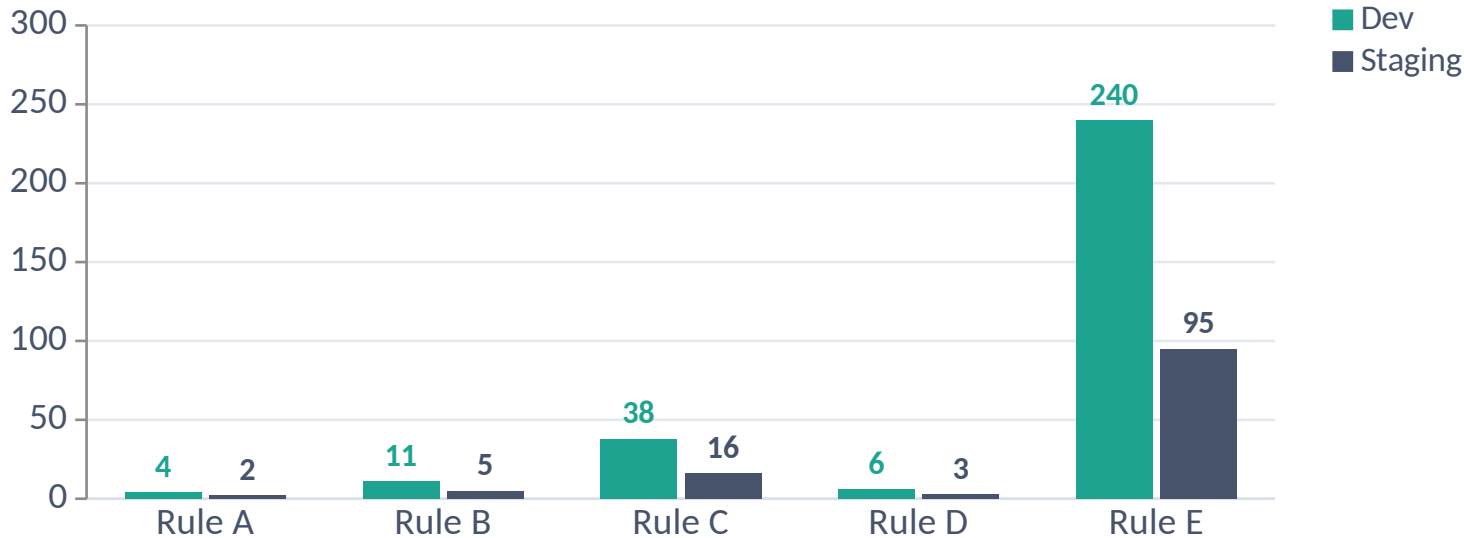
Created Sep 18, 2026 @ 22:10:25.375 by [REDACTED]

Updated Sep 18, 2026 @ 22:10:25.375 by [REDACTED]

☰ Affe

```
process.parent.name IS cscript.exe
AND process.name IS powershell.exe
AND process.parent.args MATCHES *Microsoft.SystemCenter.*.vbs*
AND user.name IS ONE OF [svc-scom-admin] [REDACTED]
AND host.name MATCHES [REDACTED]*
```

Gate 2: how loud would this have been?



DEV

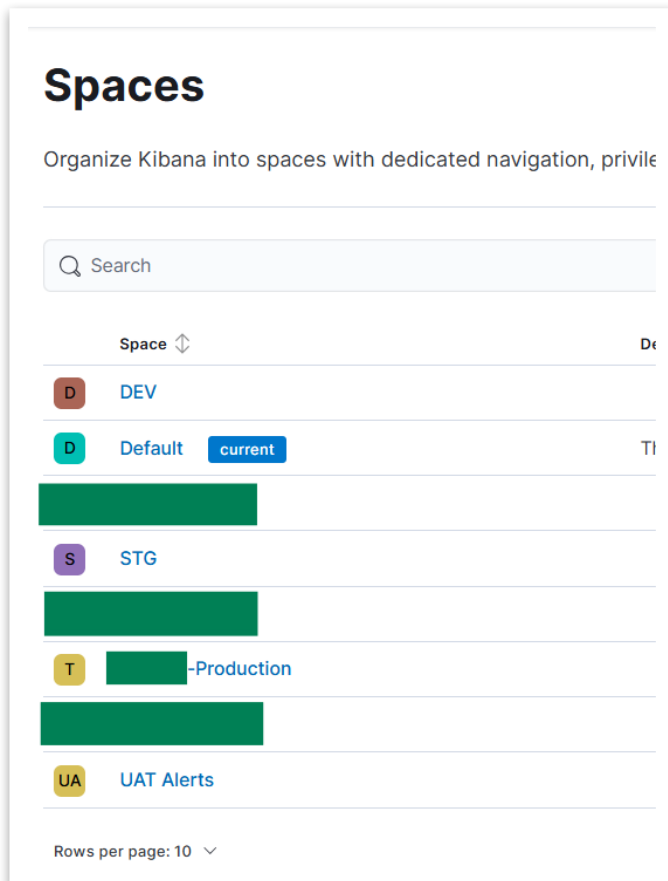
>

STAGING

>

PROD

What it looks like in Kibana



RESULTS

What the gates actually caught

300+

rules stopped before Production

70+

field validation failures caught

15,000+

alerts per month, had it shipped

What Changed For Us

No surprise

rule updates reaching
production unmeasured

30 days

of volume evidence behind every
promoted rule

One path

for install, tuning, promotion
and rollback

Severity levels

Levels	Count ↓
● Medium	234
● High	219
● Low	8



Detection rules (SIEM)

Some Elastic rules have updates available. Update them to ensure you get the best detection experience. Review and update in the Rules page.

Installed Rules

526

Rule Monitoring

526

Rule Updates

14

🔍 Rule name, index pattern (e.g., "filebeat-*"), or MITRE ATT&CK™ tactic or technique (e.g., "Defense Evasion" or "Privilege Escalation")

Showing 41-60 of 526 rules

Selected 0 rules

[Select all 526 rules](#)

Bulk actions ▾

[Refresh](#)

[Clear filters](#)

The promotion utility

1. Schema validation

2. Field validation

3. Volume analysis

4. Staged soak

DR DR Activation
FAILOVER CONSOLE

OPERATIONS

 DR Failover Monitoring

ADMINISTRATION

 ManagementDR rules. Switch back to **Both** to fail back.

DETECTION RULES

Production · space "default" · 4 enabled

Active cluster

Production

DR

Enabled

Disabled

All

Search name or tag...

RULE	SEVERITY	RISK	TYPE	STATE
DR Test Rule - Firewall Any Event dr-failover	Low	21	query	ENABLED
DR Test Rule - Linux Any Event dr-failover	Low	21	query	ENABLED
DR Test Rule - Switch Any Event dr-failover	Low	21	query	ENABLED
DR Test Rule - Windows Any Event dr-failover	Low	21	query	ENABLED

< Prev

1-4 of 4

Next >

WATCHER WATCHES

Production · 4 total

Active cluster

Production

DR

All

Active

Inactive

Search id or tag...

☐ Show managed

WATCH	SCHEDULE	ACTIONS	LAST CHECKED	STATE
-------	----------	---------	--------------	-------

APPLICATION LOGS

All

Info

Warn

Error

Filter...

☒ Follow

Clear

(2026-08-
19T22:22:53.143633+00:00)
mode=P1 ---
22:22:53 **WARNING** dr_activation Still in P1 (complete/partial
ingestion failure)
22:22:53 **INFO** dr_activation --- Monitoring cycle end ---

AUDIT TRAIL

DR cluster · most recent first

P1 Ingestion Failure

19m ago

Success · windows, firewall, linux, switch

Production Outage

19m ago

Success · windows, firewall, linux, switch

Partial Production Outage

20m ago

Success · windows

Detection Rule Sync

21m ago

Success

What you can pick up from this

- 1 Treat detection rules as shipped software — they need an environment path, not just an install button.
- 2 Measure alert volume before a rule reaches an analyst, not after.
- 3 You can build this with the cluster you already have; just be honest about what spaces isolate.

Future scope

- **AI middleware**
- **DR sync utility**
- **Smart Mustache templates**
- **Sharper Attack Discovery**



Thank you - QUESTIONS?



Kartik Rajesh

Senior DevSecOps Engineer



Connect on LinkedIn

Scan the QR code

